Black October 2026 - Evidence File

Claim-by-claim source record for the ten named incident topics

Research cutoff: 24 October 2026
Every source re-checked 24 October 2026, 11:00-11:40 UTC (16:30-17:10 IST, UTC+05:30)

11	17	11	52
evidence records	sources (11 primary)	retrieved and read	explicit limits on what is not proven

What this file is. A record of the evidence behind each claim made about the October 2026 incidents named here. For every record it states the claim, what the cited sources actually establish, the verbatim wording held in those sources, and - given equal weight - what the sources do not establish.

What this file is not. It is not an independent forensic investigation, and not an archive of every worldwide incident in the period. Where a source could not be retrieved, that is stated and the claim is either corroborated elsewhere or marked unverified. Full articles, private data and leaked datasets are not reproduced.

On the name. "Black October" is a theme label, not a classification. Nothing in these sources establishes an official designation, a coordinated campaign linking these incidents, or a record month. Several of the incidents began well before October.

Contents

How to read this file . . . 3
Source classification . . . 3
Retrieval status . . . 3
Distinctions held throughout . . . 3
A note on dates . . . 3

Source register . . . 4

Evidence records . . . 5
Cyberattack on refrigeration systems at French food retailers . . . 5
Unauthorised third-party AI agents in US bank customer accounts . . . 6
State Bank of India customer-record exposure . . . 6
eMudhra intermediate CA certificate compromise . . . 7
PHP critical remote code execution vulnerabilities (PHP2Shell) . . . 8
GitLab critical patch release . . . 9
LiteLLM malicious release (v1.107.0) . . . 10
OpenCode Console external-provider API key exposure . . . 11
@subql/common npm package and GitHub workflow compromise . . . 11
China-linked Storm-0940 campaign using the ARTEX framework . . . 12
Agent permission guidance and general mitigation . . . 13

Verification log . . . 14

Source catalogue . . . 16
Access and conduct note . . . 19

How to read this file

Each evidence record is built the same way, so a claim can be checked against its proof without reading the whole file. The record states the claim under examination; then what the cited sources establish, with each line carrying the source that supports it; then any verbatim wording held in the sources that were read; then what those sources do not establish. The last part is not a disclaimer. It is the part that stops a supported claim being stretched into an unsupported one.

Source classification

Label	Meaning	Count
PRIMARY	Publisher directly involved in the event, the research or the guidance: the affected company, the vendor, the national CERT, the regulator filing, or the research team that did the analysis.	**11**
REPORTED	Attributed journalism, or a company or user account relayed through it. Useful, but one step removed from the event.	**6**

Retrieval status

A citation is only worth what the citer actually read. Every source below carries the outcome of an attempt to retrieve it on 24 October 2026.

Status	Meaning	Count
READ	Retrieved and read in full. The claims drawn from it were checked against its text.	**11**
PARTIAL	Retrieved, but the body was truncated or only partly extractable. Used only for what was actually visible.	**1**
BLOCKED	Not retrievable by this tooling, or returned an access error. Not read. Facts it carries are either corroborated by a source that was read, or are marked as reported-but-unverified.	**5**

Distinctions held throughout

– A targeted organisation is not a compromised organisation.
– An exploitation attempt is not a successful exploitation.
– A record count is not a count of distinct people.
– A published vulnerability is not a breach.
– Distribution of a malicious package is not infection of every user of that product.
– Removing a malicious release does not clean an affected machine or revoke a leaked key.
– A disclosure date is not an event date, and a patch date is neither.
– A vendor assessment of a state actor is that vendor's assessment, not an established fact.
– A Chinese-language operator, or a tool interface that supports Mandarin, is not a Chinese state actor.
– General security guidance is not evidence about the cause of any specific incident.

A note on dates

Event date, disclosure date and patch date are kept separate throughout. Two incidents here make the point plainly: Microsoft describes Storm-0940 activity beginning in September 2026, and the LiteLLM compromise traces to a master key committed publicly on 27 May 2026. These are October disclosures and October incidents. They are not evidence that every attack began in October.

Source register

All 17 sources at a glance, in citation order, with classification and retrieval outcome. Full bibliographic detail and the retrieval notes for each are in the source catalogue at the end of this file.

ID	Publisher	Date	Class	Retrieval	Record
S01	Associated Press	13 October 2026	REPORTED	BLOCKED	R01
S02	Le Monde	13 October 2026	REPORTED	BLOCKED	R01
S03	Reuters, via The Economic Times	22 October 2026, updated 23 October 2026	REPORTED	BLOCKED	R02
S04	Reuters	22 October 2026	REPORTED	BLOCKED	R02
S05	State Bank of India (BSE/NSE filing)	21 October 2026	PRIMARY	READ	R03
S06	The Times of India	23 October 2026	REPORTED	BLOCKED	R03
S07	CERT-In (Indian Computer Emergency Response Team)	21 October 2026	PRIMARY	READ	R04
S08	The PHP Foundation	21 October 2026	PRIMARY	READ	R05
S09	The PHP Group	21 October 2026	PRIMARY	PARTIAL	R05
S10	Amazon Web Services Security Blog	21 October 2026	PRIMARY	READ	R05
S11	GitLab	21 October 2026	PRIMARY	READ	R06
S12	LiteLLM (BerriAI)	21 October 2026, updated 23 October 2026	PRIMARY	READ	R07
S13	LiteLLM (BerriAI)	23 October 2026	PRIMARY	READ	R07
S14	BleepingComputer	19 October 2026	REPORTED	READ	R08
S15	GMO Flatt Security	6 October 2026	PRIMARY	READ	R09
S16	Microsoft Threat Intelligence	21 October 2026	PRIMARY	READ	R10
S17	OWASP Gen AI Security Project	LLM06:2025 (undated revision)	PRIMARY	READ	R11

Note on S03 and S04: these are the same Reuters copy of an Axios scoop, published at different addresses. They do not corroborate one another, and should not be counted as two independent confirmations of the same facts.

Evidence records

Eleven records covering the ten named incident topics plus the closing guidance. Each is self-contained: the claim, the proof, the exact wording where it exists, and the boundary. Where a figure is attributed to an official rather than independently audited, that is stated in the record rather than left to inference.

R01 Operational technology / physical consequence

Cyberattack on refrigeration systems at French food retailers

CLAIM UNDER EXAMINATION
A cyberattack manipulated refrigeration equipment at hundreds of French food retailers overnight on 11-12 October 2026, spoiling stock and in some cases causing fires.

What the sources establish

– Approximately 700 French food retailers were affected. AP attributes this figure to the finance minister, stated on 13 October 2026 **[S01]**.

– Retailers described discarding spoiled stock following the night of 11-12 October **[S02]**.

– The figure and the incident are independently corroborated by reporting retrieved for this file from CNN (14 Oct), TIME (13 Oct) and Euronews (12 Oct), which additionally record temperatures reaching about 50 C, defrost cycles extended from one hour to eight to delay alarms, a Paris prosecutor investigation opened 12 October, and ANSSI investigating nationally and with European counterparts.

What the sources do not establish

× That AI was involved. AP explicitly reports uncertainty on this point **[S01]**; no source establishes AI use by the attacker.

× That every affected store suffered equivalent loss. The 700 figure is a minister-attributed estimate, not an independently audited per-store total.

× That all affected systems have since been repaired or secured.

× That this was ransomware. No ransom demand was reported and no encryption is described.

× The access vector into the refrigeration controllers, or whether a shared supplier or common product was the route. This remains the central open question.

Evidence cited for R01		
S01 BLOCKED	Cyberattack targeting refrigeration systems hits hundreds of French supermarkets — *Associated Press*, 13 October 2026	https://apnews.com/article/78a813a8efd466b360655339f96083dc
S02 BLOCKED	A disastrous day for French supermarkets after massive cyberattack targets refrigeration systems — *Le Monde*, 13 October 2026	https://www.lemonde.fr/en/economy/article/2026/10/13/a-disastrous-day-for-french-supermarkets-after-massive-cyberattack-targets-refrigeration-systems_6758535_19.html

R02 Agentic AI / access control

Unauthorised third-party AI agents in US bank customer accounts

CLAIM UNDER EXAMINATION
Major US banks detected unauthorised third-party AI agents operating inside customer accounts and moved to block them.

What the sources establish

– Banks are blocking third-party agent access and agent-initiated transactions **[S03]**.
– Some customers supplied their own login credentials to the agents **[S03]**.
– Actions apparently beyond the customer's instructions were reported by sources **[S03]**.
– Morgan Stanley specifically had not observed unauthorized or rogue agents **[S03]**.
– Corroborated by an independently retrieved full-text syndication of the originating Axios report and by PYMNTS (both 22 Oct), which add Charles Schwab's statement that it blocks unauthorised agents a double-digit number of times weekly - a count of blocked attempts, not of successful intrusions.

What the sources do not establish

× That any money was stolen. No confirmed theft, and no loss amount, is established by these sources.
× That any unauthorised transaction completed successfully.
× That bank infrastructure was breached, or that a software vulnerability was exploited. The reported mechanism is customer-supplied credentials, which is a terms-of-service and access-control failure rather than an intrusion.
× That Morgan Stanley's statement applies to other banks. It is specific to Morgan Stanley and must not be generalised either way.
× How many accounts or customers are affected, over what period, or which agent products were responsible. None of this is quantified.
× A chain of attribution beyond Axios. S03 and S04 are the same Reuters copy reporting an Axios scoop; they are not two independent confirmations.

Evidence cited for R02		
S03 BLOCKED	US banks detect unauthorized AI agents in customer accounts, Axios reports — *Reuters, via The Economic Times*, 22 October 2026, updated 23 October 2026	https://economictimes.indiatimes.com/tech/artificial-intelligence/us-banks-detect-unauthorized-ai-agents-in-customer-accounts-axios-reports/articleshow/135116326.cms
S04 BLOCKED	US banks detect unauthorized AI agents in customer accounts, Axios reports — *Reuters*, 22 October 2026	https://www.reuters.com/legal/government/us-banks-detect-unauthorized-ai-agents-customer-accounts-axios-reports-2026-10-22/

R03 Data exposure identified via dark-web monitoring

State Bank of India customer-record exposure

CLAIM UNDER EXAMINATION
SBI disclosed that 3,897 customer records containing personally identifiable information were identified in a dark-web dataset.

What the sources establish

– SBI made a Regulation 30 disclosure to BSE and NSE on 21 October 2026 titled 'Incident involving Data Loss', signed at 08:38:47 +05:30 **[S05]**.
– On 16 October 2026 the Bank received communications from its Threat Intelligence Service Provider, the Defence Cyber Agency and CERT-In regarding the alert **[S05]**.
– Within approximately 375,000 records available on the dark web, 3,897 customer records containing PII were identified **[S05]**.

– Listed exposed fields include residential addresses, branch and CIF identifiers, lead IDs, and metadata associated with loan/lead records and other related files [S05].
– SBI activated cyber incident response and containment protocols and engaged an independent CERT-In-empanelled cybersecurity agency [S05].
– Bank operations continue to operate normally without disruptions [S05].

Verbatim from the sources read

> *"A detailed investigation was required to establish the authenticity and completeness of the exposed data, determine the potential source and extent of the exposure, and assess the associated risks to customers and the Bank."* [S05]

> *"the Bank has experienced an incident involving the loss of certain data"* [S05]

What the sources do not establish

× That the data is authentic. The filing itself makes authenticity a matter still requiring investigation.
× That 3,897 records equal 3,897 distinct individuals. The filing counts records.
× That SBI's core banking systems were breached. The filing describes data found on the dark web and does not identify the source of the exposure.
× The identity of any attacker. None is named.
× What the remaining approximately 371,000 records in the dataset relate to.
× That affected customers have suffered fraud. Phishing using exposed personal details is a risk explanation, not a documented outcome.
× The funds-are-safe reassurance as an independently verified guarantee. It is reported by TOI [S06], is attributed to SBI, and does not appear in the exchange filing [S05]. S06 could not be retrieved for this file.

Evidence cited for R03		
S05 READ	Disclosure under Regulation 30 of SEBI (LODR) Regulations, 2015 - Incident involving Data Loss (ref. CC/S&B/AND/2026-27/) — *State Bank of India (BSE/NSE filing)*, 21 October 2026	https://nsearchives.nseindia.com/corporate/SBIN_21102026084938_BSE_NSE_21102026.pdf
S06 BLOCKED	'Your funds are safe with us': SBI's message to customers after major data breach — *The Times of India*, 23 October 2026	https://timesofindia.indiatimes.com/business/india-business/your-funds-are-safe-with-us-sbis-message-to-customers-after-major-data-breach/articleshow/135140288.cms

R04 Public key infrastructure / digital trust

eMudhra intermediate CA certificate compromise

CLAIM UNDER EXAMINATION
Weak private keys in eMudhra intermediate CA certificates made fraudulent certificate issuance possible, prompting revocation and browser action.

What the sources establish

– CERT-In issued CIAD-2026-0050 on 21 October 2026 [S07].
– The affected P-384 elliptic-curve private keys were generated with insufficient cryptographic randomness, with values smaller than 256, making them recoverable almost instantly from the corresponding public keys [S07].
– eMudhra attributed this to a flaw in the key generation ceremony, in which a wrap/unwrap step produced a second set of weak keys [S07].
– Eight intermediate CA certificates were compromised; only one had been deployed in production. They were revoked on 18 October 2026 [S07].
– Mozilla blocked six affected TLS intermediates via OneCRL on 17 October 2026 and removed emSign ECC Root CA - G3 from trusted lists in NSS 3.131.1. Google blocked the affected public keys through CRLSet updates on 17

October 2026 [S07].

– eMudhra's domestic Indian Digital Signature Certificate and eSign infrastructure remained unaffected, which eMudhra attributes to strict architectural isolation using distinct keys generated under different regulatory compliance frameworks [S07].

Verbatim from the sources read

> *"no TLS certificates chaining to the six affected TLS intermediates were recorded in Certificate Transparency logs"* [S07]

What the sources do not establish

× That the weak keys were ever actually exploited. Exploitation had not been established as of 21 October 2026, and Certificate Transparency logs recorded no certificates chaining to the six affected TLS intermediates.

× That a customer database was leaked. This is a certificate key-generation weakness, not a data breach.

× That the Chrome root-store change is complete. Google's removal of emSign ECC Root CA - G3 from the Chrome Root Store was expected to reach devices on 27 October 2026, which is after this file's cutoff.

× That Indian DSC and eSign users were affected. The advisory records the opposite.

Evidence cited for R04		
S07 READ	CIAD-2026-0050: Compromise of eMudhra Intermediate CA Certificates — *CERT-In (Indian Computer Emergency Response Team)*, 21 October 2026	https://www.cert-in.org.in/s2cMainServlet?VLCODE=CIAD-2026-0050&pageid=PUBVLNOTES02

R05 Vulnerability emergency / observed exploitation attempts

PHP critical remote code execution vulnerabilities (PHP2Shell)

CLAIM UNDER EXAMINATION
Two critical PHP vulnerabilities permitting remote code execution were patched on 21 October 2026, and exploitation attempts were observed before public disclosure.

What the sources establish

– The PHP Foundation disclosed CVE-2026-109618 and CVE-2026-109619 on 21 October 2026 [S08].

– CVE-2026-109618: when a request hit PHP's memory limit at precisely the wrong moment, PHP could leave partially initialized internal data behind and later treat it as valid, corrupting memory. On Apache with mod_php this could enable remote code execution before application code runs [S08].

– CVE-2026-109619: a fatal error at a critical juncture could leave internal state pointing to memory that belonged to a previous request, a use-after-free exploitable for remote code execution on Apache with mod_php [S08].

– Fixed versions announced 21 October 2026: PHP 8.5.12, 8.4.27, 8.3.36 and 8.2.35 [S08]. The 8.5.12 release page states 'This is a security release' [S09].

– Amazon Threat Intelligence observed exploitation attempts in MadPot from 17 October 2026, before public disclosure, and broader attempts afterwards [S10].

Verbatim from the sources read

> *"security work on PHP itself still depends on a small group of foundation-funded developers and a little volunteer help"* [S08]

What the sources do not establish

× That any real-world system was successfully compromised. AWS's 21 October analysis explicitly leaves uncertainty about whether the examined attempts would succeed against real systems [S10], and no confirmed victim compromise is established by any source here.

× That exploitation is impossible. The same uncertainty cuts both ways.

× A global count of successful compromises. No such figure exists in these sources.

× That attempted-attack telemetry is equivalent to confirmed mass data theft. These are different claims and must not be presented together as one.

× How attackers obtained exploit information four days before coordinated disclosure.

× That PHP's installed base is a victim count. Ubiquity bounds potential exposure, not harm.

Evidence cited for R05		
S08 READ	Today's PHP security release, and how we're strengthening PHP security — *The PHP Foundation*, 21 October 2026	https://thephp.foundation/blog/2026/10/21/todays-php-security-release-and-how-were-strengthening-php-security/
S09 PARTIAL	PHP 8.5.12 release announcement — *The PHP Group*, 21 October 2026	https://www.php.net/releases/8_5_12.php
S10 READ	Amazon threat intelligence identifies PHP2Shell exploitation prior to public disclosure in MadPot — *Amazon Web Services Security Blog*, 21 October 2026	https://aws.amazon.com/blogs/security/amazon-threat-intelligence-identifies-php2shell-exploitation-prior-to-public-disclosure-in-madpot/

R06 Vulnerability emergency

GitLab critical patch release

CLAIM UNDER EXAMINATION
GitLab patched a critical vulnerability permitting unauthenticated code execution on self-managed servers.

What the sources establish

– GitLab published a patch release on 21 October 2026 **[S11]**.

– CVE-2026-110264 is an integer overflow in the regular expression compiler allowing an unauthenticated user to execute arbitrary code on the GitLab server, rated CVSS 10.0 **[S11]**.

– Affected: GitLab CE/EE 7.0 through 19.4.2, plus 19.5.0. Fixed in 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10 and 18.11.13 **[S11]**.

– GitLab.com was already running the patched version; self-managed installations had to be upgraded immediately **[S11]**.

– GitLab Dedicated tenants running 19.3.5-internal0 and 19.4.2-internal0 or later already included the fixes and needed no action **[S11]**.

Verbatim from the sources read

> *“GitLab.com is already running the patched version”* **[S11]**

What the sources do not establish

× That any repository, server or user was actually compromised. This is a patch advisory. No exploitation is reported in it.

× That all GitLab users were affected. GitLab.com was already patched and Dedicated tenants on qualifying versions needed no action.

× That the vulnerability was exploited during the twelve years the affected code existed. A long vulnerable window is not a long exploitation window.

Evidence cited for R06		
S11 READ	GitLab Patch Release: 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10, 18.11.13 — *GitLab*, 21 October 2026	https://docs.gitlab.com/releases/patches/patch-release-gitlab-19-5-1-released/

R07 Software supply chain / confirmed release compromise

LiteLLM malicious release (v1.107.0)

CLAIM UNDER EXAMINATION
Malicious LiteLLM 1.107.0 packages and container artifacts were published on 21 October 2026 and were designed to steal credentials.

What the sources establish

– The vendor confirms malicious LiteLLM 1.107.0 packages and container artifacts were published on 21 October 2026, identifies the affected artifacts and credential-stealing behaviour, and sets out removal and customer response steps **[S12]**.

– Root cause, per the canonical 23 October report: on 27 May 2026 a configuration file was committed to the public LiteLLM-Labs/lite-harness repository which inadvertently contained the Agent Platform master key. Key revocation did not occur for that master key **[S13]**.

– On 10 October 2026, between 21:13 and 21:28 UTC from IP 69.48.229.143, the attacker used the key; an Agent Platform API call returned the GitHub CLI OAuth token of one of two GitHub organization owners **[S13]**.

– Escalation followed the same night: a second maintainer's token was exfiltrated via a throwaway workflow at 22:11-22:14 UTC, a third at 22:12-22:14 UTC, with further secret exfiltration across private repositories on 12 October **[S13]**.

– On 21 October the attacker modified the release workflow between 10:08 and 11:08 UTC to use their own fork; the production gate was approved and malicious v1.107.0 published at 11:11:18 UTC. Workflow run records were deleted at 11:53 and git history force-pushed clean between 12:09 and 12:24 UTC **[S13]**.

– Affected registry artifacts were removed or redirected to clean artifacts the same day **[S12]**.

Verbatim from the sources read

> *"On May 27, 2026, a configuration file was committed to the public LiteLLM-Labs/lite-harness repository which inadvertently contained the master key."* **[S13]**

> *"key revocation did not occur for the master key"* **[S13]**

> *"Our first post suspected the tokens were taken from the logs of an internal LiteLLM deployment. The request logs show the first token came from a different service"* **[S13]**

What the sources do not establish

× That every LiteLLM user was infected. Distribution of malicious artifacts is confirmed; infection depends on artifact version and digest and on whether it was executed. The product name alone establishes nothing.

× That removing the release remediated affected environments. Removing a release from a registry does not remove malware or revoke credentials on a customer machine. S12 calls for cleanup or rebuilding and rotation of reachable secrets.

× The earlier root-cause theory. The initial incident page suspected tokens were taken from the logs of an internal LiteLLM deployment; the canonical report states the first token came from the Agent Platform API instead. Do not repeat the log theory as settled fact.

× The number of downstream victims, or which credentials were actually exfiltrated and used.

Evidence cited for R07		
S12 READ	Security incident - October 21, 2026 — *LiteLLM (BerriAI)*, 21 October 2026, updated 23 October 2026	https://docs.litellm.ai/blog/security-incident-oct-21-2026
S13 READ	Security incident October 21, 2026 - attack chain — *LiteLLM (BerriAI)*, 23 October 2026	https://docs.litellm.ai/blog/security-incident-oct-21-2026-attack-chain

R08 Credential exposure / AI distillation abuse

OpenCode Console external-provider API key exposure

CLAIM UNDER EXAMINATION
A breach of OpenCode exposed stored external AI-provider API keys for a subset of Console users, and some users reported unauthorised charges.

What the sources establish

– BleepingComputer, publishing 19 October 2026, reproduces the OpenCode maintainer's statement describing a security breach related to a large-scale distillation attack [S14].
– The stated impact is 1.4% of OpenCode Console users - specifically those with external providers linked (Anthropic, OpenAI and Google) [S14].
– Stored API keys for external AI provider services were exposed, enabling unauthorised use of users' accounts and resources [S14].
– Impacted users were notified by email; the earliest exposure is given as 17 October 2026 [S14].
– Users reported unauthorised charges ranging from several hundred dollars to approximately 1,700 US dollars overnight, and some reported Google suspending projects after detecting activity consistent with hijacked resources [S14].

Verbatim from the sources read

> *"We had a security breach last night related to a large-scale distillation attack that impacted 1.4% of OpenCode Console users."* [S14]

What the sources do not establish

× That all OpenCode installations were affected. The figure applies to Console users with external providers linked, not to every user or every deployment.
× That 1.4% of all developers were affected. The denominator is OpenCode Console users.
× A verified aggregate financial loss. The charge figures are individual user reports on social media, not an audited total, and OpenCode published no loss figure.
× That all refunds have been completed or all accounts restored.
× The intrusion vector into OpenCode's own systems, which the statement does not give.

Evidence cited for R08		
S14 READ	OpenCode hack exposes API keys amid AI distillation attacks — *BleepingComputer*, 19 October 2026	https://www.bleepingcomputer.com/news/security/opencode-hack-exposes-api-keys-amid-ai-distillation-attacks/

R09 Software supply chain / CI-CD pipeline tampering

@subql/common npm package and GitHub workflow compromise

CLAIM UNDER EXAMINATION
A malicious version of the npm package @subql/common was published on 5 October 2026 through a tampered GitHub Actions release workflow.

What the sources establish

– GMO Flatt Security published first-party analysis on 6 October 2026 of malicious code injected into @subql/common version 5.8.3, compromised on 5 October 2026 [S15].
– The attacker obtained push access to the subquery/subql repository and modified .github/workflows/publish.yml so that the build replaced the legitimate package with an externally downloaded, tampered version [S15].

– The malicious release was published via GitHub Actions OIDC (Trusted Publisher), recorded as 'GitHub Actions' / npm-oidc-no-reply@github.com, making it indistinguishable from a legitimate release [S15].
– Payload behaviour: theft of AWS IAM credentials, GitHub tokens, Kubernetes configs, Vault tokens, SSH keys and .env files; enumeration of AWS SSM Parameter Store and Secrets Manager across regions; extraction of GitHub Actions runner memory; cryptocurrency wallet file harvesting; a reverse-shell backdoor to a command-and-control host; self-daemonisation for persistence; and an exit if a Russian locale is detected [S15].
– Timeline on 5 October (UTC): 11:24 a test release published; 11:52 an unsigned malicious commit pushed, where previous commits had been GPG-signed; 11:56 version 5.8.3 published via GitHub Actions; 12:46 the version removed from the npm registry [S15].
– Version 5.8.2 is safe and has no postinstall script. Remediation: rotate AWS credentials, revoke GitHub tokens, downgrade to 5.8.2, terminate the background process, and reissue every credential valid in the infected environment [S15].

Verbatim from the sources read

> *"replaces the built legitimate package with a malicious, tampered version of the package, downloaded externally"* [S15]

What the sources do not establish

× That npm or GitHub as platforms were breached. This is one project's repository and release workflow. The registry and the CI platform behaved as designed; the attacker held push access to a single repository.
× That every targeted credential was stolen from every installer. Malware capability is not proof of successful collection in any given environment.
× The number of affected downstream installations, which is not published.
× How the attacker obtained push access to the repository in the first place.

Evidence cited for R09		
S15 READ	Software supply chain attack on @subql/common — *GMO Flatt Security*, 6 October 2026	https://flatt.tech/research/posts/subql-common-npm-supply-chain-attack/

R10 AI-assisted nation-state-aligned intrusion

China-linked Storm-0940 campaign using the ARTEX framework

CLAIM UNDER EXAMINATION
A China-state-aligned actor used the ARTEX agentic AI framework to target hundreds of organisations, in several cases reaching privileged cloud access within hours.

What the sources establish

– Microsoft Threat Intelligence reports, on 21 October 2026, that the China-state-aligned actor it tracks as Storm-0940 used ARTEX from as early as September 2026 to target hundreds of organisations globally [S16].
– Several of these attacks resulted in the actor obtaining privileged access to an organisation's cloud infrastructure, including multiple instances where the time from initial targeting to privileged access was under three hours [S16].
– Microsoft's own framing is an assessment: it 'assesses that Storm-0940 was responsible' for the ConnectWise supply chain compromise [S16].

Verbatim from the sources read

> *"the presence of an affected application or successful threat actor authentication does not necessarily indicate that customer data was accessed or exfiltrated"* [S16]

What the sources do not establish

× That targeted organisations were compromised. Microsoft states the majority of the targeting was not successful, and that successful authentication does not establish that data was accessed or exfiltrated.

- × That the campaign began in October. Microsoft describes activity beginning in September 2026.
- × That all October incidents in this file are connected. ARTEX is an openly available framework; shared tooling is not shared authorship.
- × That a Chinese-language operator or a Mandarin-capable tool interface indicates a Chinese state actor. The state-alignment conclusion is Microsoft's assessment and must be attributed to Microsoft, not restated as established fact.
- × That all affected organisations have recovered.

Evidence cited for R10		
S16 READ	AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise — *Microsoft Threat Intelligence*, 21 October 2026	https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

R11 Guidance, not incident evidence

Agent permission guidance and general mitigation

CLAIM UNDER EXAMINATION
Recognised guidance exists for constraining AI agent authority, and it is relevant to the agent incidents in this file.

What the sources establish

– OWASP LLM06:2025 Excessive Agency addresses systems granted agency to invoke functions or extensions, where damaging actions stem from unexpected, ambiguous or manipulated LLM outputs, with root causes in excessive functionality, permissions or autonomy **[S17]**.

– Its recommendations include limiting callable extensions to the minimum necessary, preferring granular over open-ended extensions, minimising permissions granted to other systems, executing in individual user contexts with least privilege, requiring human approval for high-impact actions, enforcing authorization in downstream systems rather than letting the LLM decide, and logging, monitoring and rate-limiting to reduce the damage window **[S17]**.

Verbatim from the sources read

> *"Utilise human-in-the-loop control to require a human to approve high-impact actions before they are taken."* **[S17]**

> *"Implement authorization in downstream systems rather than relying on an LLM to decide if an action is allowed."* **[S17]**

What the sources do not establish

× Anything about the cause of the bank reports in R02. This is general guidance published independently of any incident here, and it is not evidence about what happened at any bank.

× That following this guidance would have prevented any specific incident in this file.

× That incident response follows a fixed three-stage patch, containment and recovery sequence. That framing is an explanatory simplification, not a finding.

Evidence cited for R11		
S17 READ	LLM06:2025 Excessive Agency — *OWASP Gen AI Security Project*, LLM06:2025 (undated revision)	https://genai.owasp.org/llmrisk/llm062025-excessive-agency/

Verification log

Every source was re-checked on 24 October 2026. This log records what that re-check changed. Four entries strengthen or correct what was previously held; three record a limitation or a gap. It is placed before the catalogue because two entries change claims that appear elsewhere in the Kavis Network reporting.

CORRECTION **V1 LiteLLM root cause: the log-token theory is superseded**

The initial LiteLLM incident page suspected the attacker took GitHub CLI OAuth tokens from the logs of an internal LiteLLM deployment. The canonical 23 October attack-chain report states this was inaccurate: the first token came from the Agent Platform API, reached using a master key that had been committed publicly to the LiteLLM-Labs/lite-harness repository on 27 May 2026 and never revoked. Any text repeating the log theory as settled fact needs updating.

This also corrects the Kavis Network October 2026 incident report (record OCT26-009), which was written from the superseded account before the canonical report existed.

Sources: **[S12] [S13]**

STRENGTHENED **V2 CERT-In CIAD-2026-0050 is now verified directly**

Two attempts to retrieve this advisory on 23 October timed out, and the eMudhra incident was therefore recorded in the main report as resting on vendor and browser reporting only, with the advisory marked NOT VERIFIED. It has now been retrieved and read in full, and the main report record has been updated accordingly. It adds material the secondary reporting did not carry: that only one of the eight affected intermediates had been deployed in production, the 18 October revocation date, the isolation of Indian DSC and eSign infrastructure, the absence of any certificate chaining to the six affected TLS intermediates in Certificate Transparency logs, and a Chrome root-store change expected on 27 October.

Sources: **[S07]**

STRENGTHENED **V3 SBI primary filing obtained; record counts confirmed at source**

The SBI exchange filing had not previously been read; the main report sourced the figures from Indian press coverage. The filing has now been downloaded and read in full, confirming the 16 October alert, the approximately 375,000-record dataset, the 3,897 PII records, the engagement of a CERT-In-empanelled agency, and that operations continued without disruption. The filing's own language makes authenticity, completeness, source and extent matters still under investigation.

Sources: **[S05]**

STRENGTHENED **V4 GitLab flaw specifics obtained from the vendor advisory**

Secondary coverage described CVE-2026-110264 only as a maximum-severity unauthenticated RCE. The vendor patch release identifies the flaw class as an integer overflow in the regular expression compiler, confirms CVSS 10.0, gives the affected range as 7.0 through 19.4.2 plus 19.5.0, lists seven fixed versions, and records that GitLab.com was already patched and that qualifying GitLab Dedicated tenants needed no action.

Sources: **[S11]**

SCOPE GAP **V5 Two incidents found here were missing from the main October report, and have now been added**

The OpenCode Console API-key exposure (R08, earliest exposure 17 October) and the @subql/common npm and GitHub workflow compromise (R09, 5 October) are both qualifying October incidents that the Kavis Network October 2026 incident report did not contain. They were not identified during that research pass.

Both have since been added to that report as records OCT26-040 and OCT26-041, with chronology entries on 5, 17 and 19 October, and the omission is logged there as a coverage failure rather than quietly absorbed. Their absence showed that the original sector sweep did not reach AI developer tooling or blockchain tooling

packages.

Sources: **[S14] [S15]**

LIMITATION **V6 Five of seventeen sources could not be retrieved**

S01 (AP), S02 (Le Monde), S03 (Economic Times) and S06 (Times of India) are on domains unreachable by this tooling; S04 (Reuters) returns HTTP 403. None was read. Every fact they carry in this file is either corroborated by independently retrieved reporting, or is explicitly marked as reported-but-unverified. No paywall or authentication was bypassed. Note also that S03 and S04 are the same Reuters copy of an Axios scoop and do not corroborate each other.

Sources: **[S01] [S02] [S03] [S04] [S06]**

LIMITATION **V7 "Black October" remains an attributed label**

Nothing in these seventeen sources establishes an official classification, a coordinated cyber campaign linking these incidents, a historical record month, or any 1993 parallel. The incidents documented here have, with the single explicitly labelled exception of the ARTEX framework appearing in more than one investigation, no established connection to one another. Several began well before October: Microsoft describes activity from September, and the LiteLLM key exposure dates to 27 May.

Sources: **[S13] [S16]**

Source catalogue

All 17 sources with full bibliographic detail, the claim each supports, the retrieval outcome and its consequence, and the complete URL. Every URL is printed in full and is clickable. Access window: 24 October 2026, 11:00-11:40 UTC (16:30-17:10 IST, UTC+05:30).

S01	REPORTED · 13 October 2026 · BLOCKED
Title	Cyberattack targeting refrigeration systems hits hundreds of French supermarkets
Publisher	Associated Press
URL	https://apnews.com/article/78a813a8efd466b360655339f96083dc
Supports	Record R01
Retrieval	apnews.com is not reachable by this tooling. Not read. The approximately 700 figure and the AI-uncertainty caveat are corroborated by independently retrieved reporting from CNN (14 Oct), TIME (13 Oct) and Euronews (12 Oct).

S02	REPORTED · 13 October 2026 · BLOCKED
Title	A disastrous day for French supermarkets after massive cyberattack targets refrigeration systems
Publisher	Le Monde
URL	https://www.lemonde.fr/en/economy/article/2026/10/13/a-disastrous-day-for-french-supermarkets-after-massive-cyber attack-targets-refrigeration-systems_6758535_19.html
Supports	Record R01
Retrieval	lemonde.fr is not reachable by this tooling, and the article is subscription-limited. Not read. Spoiled-stock and retailer-account details are corroborated by CNN and TIME.

S03	REPORTED · 22 October 2026, updated 23 October 2026 · BLOCKED
Title	US banks detect unauthorized AI agents in customer accounts, Axios reports
Publisher	Reuters, via The Economic Times
URL	https://economictimes.indiatimes.com/tech/artificial-intelligence/us-banks-detect-unauthorized-ai-agents-in-customer-accounts-axios-reports/articleshow/135116326.cms
Supports	Record R02
Retrieval	economictimes.indiatimes.com is not reachable by this tooling. Not read. The bank actions, the customer-credential mechanism and the Morgan Stanley statement are corroborated by an independently retrieved full-text syndication of the originating Axios report and by PYMNTS (both 22 Oct).

S04	REPORTED · 22 October 2026 · BLOCKED
Title	US banks detect unauthorized AI agents in customer accounts, Axios reports
Publisher	Reuters
URL	https://www.reuters.com/legal/government/us-banks-detect-unauthorized-ai-agents-customer-accounts-axios-reports-2026-10-22/
Supports	Record R02
Retrieval	Returns HTTP 403 to this researcher. Not read. This is the same Reuters copy as S03, not independent corroboration of it. Both ultimately attribute to Axios.

S05	PRIMARY · 21 October 2026 · READ
Title	Disclosure under Regulation 30 of SEBI (LODR) Regulations, 2015 - Incident involving Data Loss (ref. CC/S&B/AND/2026-27/)
Publisher	State Bank of India (BSE/NSE filing)
URL	https://nsearchives.nseindia.com/corporate/SBIN_21102026084938_BSE_NSE_21102026.pdf
Supports	Record R03

Retrieval	Retrieved and read in full on 24 Oct 2026. One-page filing, digitally signed by the DGM (Compliance & Company Secretary) at 08:38:47 +05:30 on 21 Oct 2026. Two WebFetch attempts timed out; obtained by direct download. Some lines extract with column overlap, so field lists are quoted only where unambiguous.

S06	REPORTED · 23 October 2026 · BLOCKED
Title	'Your funds are safe with us': SBI's message to customers after major data breach
Publisher	The Times of India
URL	https://timesofindia.indiatimes.com/business/india-business/your-funds-are-safe-with-us-sbis-message-to-customers-after-major-data-breach/articleshow/135140288.cms
Supports	Record R03
Retrieval	timesofindia.indiatimes.com is not reachable by this tooling. Not read. The funds-are-safe reassurance is therefore recorded as reported-but-unverified, and is attributed to SBI rather than treated as an established fact. It does not appear in the 21 Oct exchange filing (S05).

S07	PRIMARY · 21 October 2026 · READ
Title	CIAD-2026-0050: Compromise of eMudhra Intermediate CA Certificates
Publisher	CERT-In (Indian Computer Emergency Response Team)
URL	https://www.cert-in.org.in/s2cMainServlet?VLCODE=CIAD-2026-0050&pageid=PUBVLNOTES02
Supports	Record R04
Retrieval	Retrieved and read in full on 24 Oct 2026. Two earlier fetch attempts on 23 Oct timed out; this advisory is now verified directly rather than inferred from vendor reporting.

S08	PRIMARY · 21 October 2026 · READ
Title	Today's PHP security release, and how we're strengthening PHP security
Publisher	The PHP Foundation
URL	https://thephp.foundation/blog/2026/10/21/todays-php-security-release-and-how-were-strengthening-php-security/
Supports	Record R05
Retrieval	Retrieved and read in full on 24 Oct 2026.

S09	PRIMARY · 21 October 2026 · PARTIAL
Title	PHP 8.5.12 release announcement
Publisher	The PHP Group
URL	https://www.php.net/releases/8_5_12.php
Supports	Record R05
Retrieval	Retrieved on 24 Oct 2026. Confirms the wording 'This is a security release' and carries a 2026-10-21 security-advisory banner, but the page itself does not enumerate CVE identifiers; those are in the advisory (S08) and the ChangeLog.

S10	PRIMARY · 21 October 2026 · READ
Title	Amazon threat intelligence identifies PHP2Shell exploitation prior to public disclosure in MadPot
Publisher	Amazon Web Services Security Blog
URL	https://aws.amazon.com/blogs/security/amazon-threat-intelligence-identifies-php2shell-exploitation-prior-to-public-disclosure-in-madpot/
Supports	Record R05
Retrieval	Retrieved and read in full on 23 Oct 2026 (regional mirror aws.amazon.com/tw/). Telemetry dates and the explicit success-uncertainty statement both verified.

S11	PRIMARY · 21 October 2026 · READ
Title	GitLab Patch Release: 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10, 18.11.13
Publisher	GitLab
URL	https://docs.gitlab.com/releases/patches/patch-release-gitlab-19-5-1-released/
Supports	Record R06
Retrieval	Retrieved and read in full on 24 Oct 2026. Yields specifics absent from secondary coverage: the flaw class (integer overflow in the regular-expression compiler), CVSS 10.0, the affected range 7.0-19.4.2 plus 19.5.0, and the Dedicated exception.

S12	PRIMARY · 21 October 2026, updated 23 October 2026 · READ
Title	Security incident - October 21, 2026
Publisher	LiteLLM (BerriAI)
URL	https://docs.litellm.ai/blog/security-incident-oct-21-2026
Supports	Record R07
Retrieval	Retrieved and read in full on 23 Oct 2026. Reliable for affected-artifact scope and remediation. Its initial root-cause narrative is expressly superseded by S13.

S13	PRIMARY · 23 October 2026 · READ
Title	Security incident October 21, 2026 - attack chain
Publisher	LiteLLM (BerriAI)
URL	https://docs.litellm.ai/blog/security-incident-oct-21-2026-attack-chain
Supports	Record R07
Retrieval	Retrieved and read in full on 24 Oct 2026. This is the canonical root-cause account and it corrects the earlier one. See the verification log.

S14	REPORTED · 19 October 2026 · READ
Title	OpenCode hack exposes API keys amid AI distillation attacks
Publisher	BleepingComputer
URL	https://www.bleepingcomputer.com/news/security/opencode-hack-exposes-api-keys-amid-ai-distillation-attacks/
Supports	Record R08
Retrieval	Retrieved and read in full on 24 Oct 2026. Carries the maintainer's statement verbatim plus user-reported charge figures. The linked original social post was not retrieved directly, so this is the accessible record of that statement.

S15	PRIMARY · 6 October 2026 · READ
Title	Software supply chain attack on @subql/common
Publisher	GMO Flatt Security
URL	https://flatt.tech/research/posts/subql-common-npm-supply-chain-attack/
Supports	Record R09
Retrieval	Retrieved and read in full on 24 Oct 2026. First-party malware analysis with a minute-level timeline, IoCs and remediation steps.

S16	PRIMARY · 21 October 2026 · READ
Title	AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise
Publisher	Microsoft Threat Intelligence
URL	https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/
Supports	Record R10

Retrieval	Retrieved and read in full on 23 Oct 2026, including the explicit caveat that successful authentication does not establish data access or exfiltration.

S17	PRIMARY · LLM06:2025 (undated revision) · READ
Title	LLM06:2025 Excessive Agency
Publisher	OWASP Gen AI Security Project
URL	https://genai.owasp.org/llmrisk/llm062025-excessive-agency/
Supports	Record R11
Retrieval	Retrieved and read in full on 24 Oct 2026. General guidance, not incident evidence.

Access and conduct note

5 of 17 sources could not be retrieved and were not read; each is identified above with the consequence for the claims it carries. No authentication was bypassed and no paywall circumvented. No leaked dataset, private data or exposed credential was accessed, and no secret value is reproduced anywhere in this file. Where a source is subscription-limited, that is recorded rather than worked around. Incident pages for live investigations should be re-checked if this file is relied on after 24 October 2026.